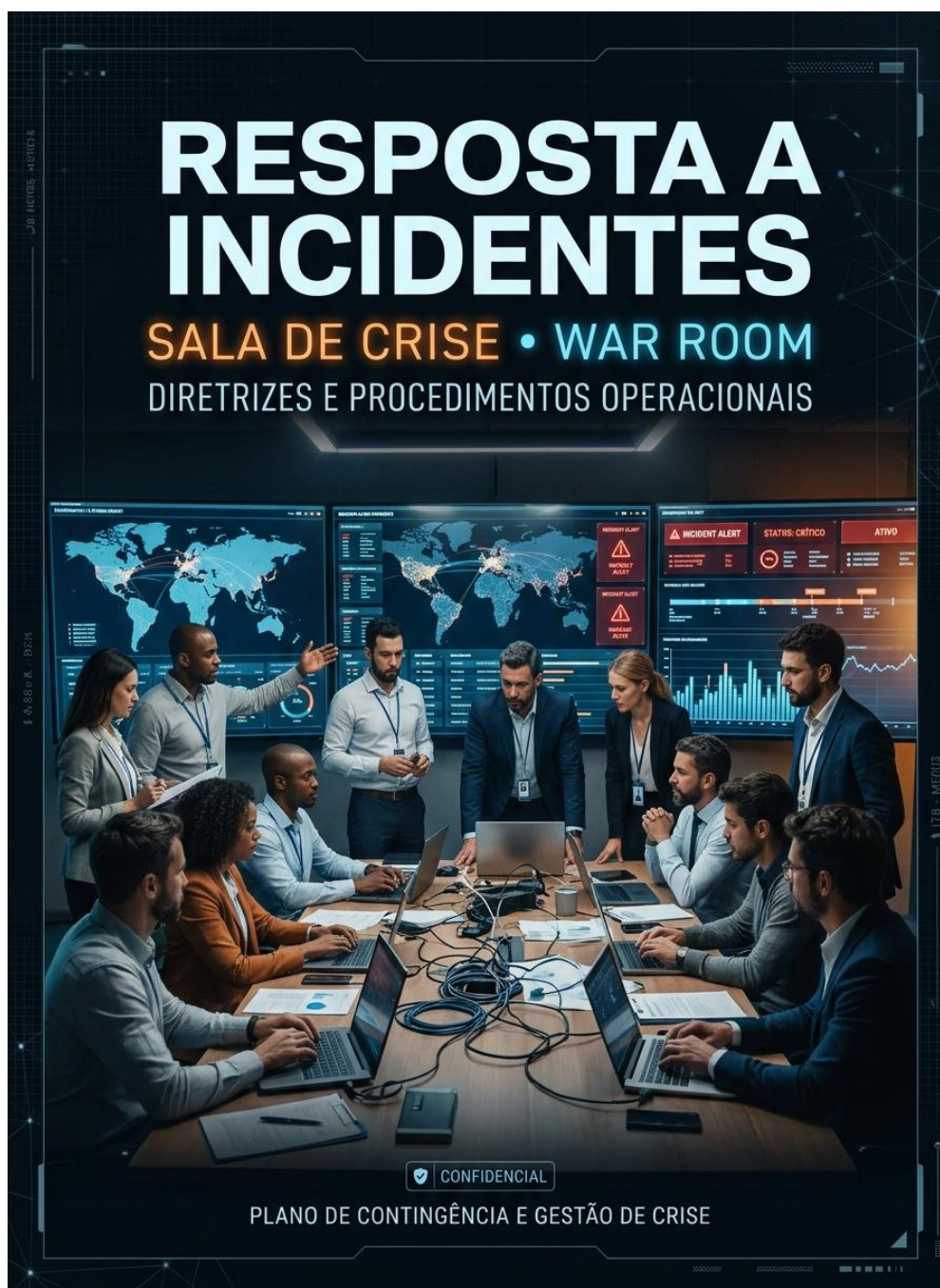


POP – Atuação em War Room. Como atuar durante uma reunião com clientes.



Versão	Área	Classificação	Criador	Criação
1.0	Resposta a Incidente (CSIRT)	Uso Interno	Thiago H M da Silva	14/09/2026

Sumário

Objetivo	3
Princípios de atuação.....	3
Antes de Entrar na War Room	3
Registro no ITSM	4
Documentação durante a War Room	6
Abertura da War Room.....	6
Perguntas Essenciais ao Cliente	7
Escopo do Incidente	8
Impacto no Negócio	8
Linha do Tempo	9
Determinação da Atividade	9
Determinação da Atividade	10
Contenção.....	11
Propagação	12
Exfiltração	12
Definição de responsáveis.....	13
Atualização do ITSM Após a War Room	13
Encerramento da Primeira War Room.....	14
Fechamento e Comunicação	15
Encerramento do Incidente no ITSM.....	15
Registro da Conclusão	15
Checklist Rápido – 5W + 1H.....	16
Regra de Ouro da War Room.....	17
Fluxo Completo do Processo	17
Perguntas Essenciais – Versão de Bolso.....	17
Princípios Fundamental de Documentação	18
Responsabilidade do Analista de IR.....	18

Objetivo

Estabelecer um processo padronizado para atuação em **War Rooms de Resposta a Incidentes com clientes**, garantindo organização da comunicação, coleta inicial de informações, definição de responsabilidade, preservação de evidências e condução estruturada da investigação.

Objetivo da War Room inicial não é necessariamente determinar imediatamente a causa do incidente, mas **entender o cenário, estabelecer fatos conhecidos, identificar impactos e definir as próximas ações**.

Toda atividade relevante relacionada ao incidente deverá ser registrada no **sistema de IT2M**, garantindo rastreabilidade desde abertura da investigação até seu encerramento.

Princípios de atuação

Durante uma War Room, o analista deve:

- Manter a postura calma e objetiva.
- Trabalhar inicialmente com **fatos**, evitando conclusões precipitadas.
- Diferenciar claramente:
 - Fato: Informação comprovada.
 - Indício: Evidência que sugere determinado comportamento.
 - Hipótese: Possibilidade ainda não confirmada.
 - Conclusão: Hipótese validada por evidência.
- Registrar decisões, ações e responsáveis.
- Manter o chamado do ITSM atualizado durante toda a investigação.
- Evitar ações destrutivas antes da preservação das evidências.
- Não atribuir autoria sem evidências suficientes.
- Manter o cliente informado sobre o que está sendo investigado e o que ainda é desconhecido.
- Garantir que as ações executadas possam ser posteriormente auditadas e reproduzidas.

Antes de Entrar na War Room

Sempre que possível, realizar uma preparação rápida antes da reunião.

Informações Disponíveis

Verificar:

- Ticket/Incidente relacionado.
- Alerta que originou a investigação, se gerou algum alerta.
- Data e horário da detecção do incidente.
- Host(s) envolvidos.

- IPs.
- Hashes.
- Domínios/URLs.
- Processos.
- Eventos de autenticação.
- Possíveis alertas relacionados.
- Evidências já coletadas.
- Ações já realizadas.
- Analistas envolvidos.
- Severidade atribuída.
- Comunicação anteriores com o cliente.

Perguntas Fundamentais

Antes da reunião, tente responder:

“O que sabemos até agora?”

E

“O que ainda não sabemos?”

Essas perguntas ajudam a evitar que a War Room comece de maneira desorganizada.

Registro no ITSM

O ITSM deve ser considerado o registro oficial da atividade de resposta ao incidente.

Antes de iniciar a War Room, o analista deve verificar se já existe um chamado relacionado ao caso, ou não.

Verificar existência de chamado

Pesquisar na ferramenta de ITSM utilizando, quando disponíveis:

- ID do alerta.
- Título da detecção.
- Host.
- Usuário
- IP.
- Hash.
- Domínio.
- Nome do Incidente.
- Número do chamado relacionado, caso tenha um.

Se já existir um chamado aberto

Validar:

- Número do ticket.
- Data da abertura.
- Responsável pelo ticket.
- Status.
- Severidade / prioridade.
- Descrição inicial.
- Evidências já registradas no ticket.
- Ações já realizadas até então.
- Última atualização do caso.
- Equipes envolvidas até o momento.

Se o chamado existente representar o mesmo do incidente, **utilizá-lo como registro principal**, evitando a criação desnecessária de chamados duplicados.

Caso exista um chamado relacionado, mas não seja o chamado principal do incidente, registrar as ações feitas no chamado principal, e vincular ele ao chamado primário, para ter todas as ações concentradas em um único ponto.

Caso não exista chamado aberto

Criar um novo chamado no ITSM antes ou imediatamente após o início da War Room. O chamado deverá conter, sempre que possível:

Identificação

- Título do incidente.
- Data e horário da detecção.
- Data e horário da abertura do incidente.
- Cliente e ambiente impactado.
- Origem da detecção.
- Analista responsável pela detecção.
- Equipe responsável.
- Severidade/prioridade inicial do caso.

Descrição Inicial

- O que foi detectado.
- Como foi detectado.
- Ativos inicialmente envolvidos no incidente.
- Usuários envolvidos.
- IOCs identificadas e conhecidas até o momento.
- Impacto causado até o momento.

Observação: Não apresente hipóteses como se fosse fatos.

Documentação durante a War Room

Durante toda a reunião, o analista responsável pelo registro deve atualizar o chamado no ITSM. Quais informações são válidas para registrar?

Registrar quando:

- Informações fornecidas pelo cliente.
- Novos ativos identificados.
- Novos usuários identificados e envolvidos no incidente.
- Novas IOCs.
- Evidências relevantes.
- Hipóteses levantadas, com base nos fatos identificados.
- Resultados de consultas feitas no SIEM, utilizando hunting.
- Ações realizadas de contenção, seja pelo time de resposta a incidente ou pelo cliente.
- Ações solicitadas pelo cliente.
- Decisões críticas ou com impacto tomadas.
- Responsáveis pela condução da reunião.
- Alteração da severidade.
- Impacto real identificado.
- Medidas de contenção feitas

Regra de documentação

Sempre que uma ação relevante for realizada, registrar:

O que foi feito → Quem realizou → Quando → Resultado → Próximo passo

Exemplo:

10:35 — SOC realizou busca pelo hash identificado no Microsoft Defender. Foram encontrados 4 endpoints com o mesmo indicador. Os equipamentos foram encaminhados para análise de escopo. Responsável: SOC. Próxima ação: verificar atividade associada ao hash nos últimos 7 dias.

Abertura da War Room

Ao iniciar a reunião, o responsável pela condução deve estabelecer rapidamente:

Identificação do incidente

Perguntar:

- Qual evento motivou a abertura da War Room?
- Quanto o incidente foi identificado?
- Quem identificou o incidente?
- Qual foi o primeiro alerta ou evidência observada no incidente?
- O incidente ainda está ocorrendo no momento?
- Existem algum impacto operacional atualmente?

Confirmar o registro

Logo no início:

“Existe um chamado de ITSM para este incidente?”

Se existir:

“Qual é o número do chamado que será utilizado como registro oficial desta investigação?”

Se não existir:

“Vamos abrir um chamado para centralizar toda a documentação, evidências, ações e decisões desta War Room.”

Perguntas Essenciais ao Cliente

O que aconteceu?

Começar com uma pergunta aberta:

“Podem nos explicar, do ponto de vista de vocês, o que aconteceu e o que levou à abertura deste incidente?”

Depois, aprofundar:

- Quando perceberam o comportamento?
- Qual foi o primeiro sistema afetado?
- O comportamento foi observado por usuário, ferramenta ou equipe?
- Existe alguma mudança recente no ambiente?
- Algum administrador realizou alguma atividade relacionada?

Evite começar sugerindo uma causa.

Prefira:

“Foi identificado algum acesso incomum?”

Em vez de:

“Esse usuário foi comprometido?”

Toda informação relevante fornecida pelo cliente deve ser posteriormente registrada.

Escopo do Incidente

Essa é uma das partes mais importantes da War Room.

Verificações e perguntas:

Hosts

- Quais máquinas estão envolvidas?
- Existe uma lista de endpoints afetados?
- São servidores ou estações de trabalho?
- Existem ativos críticos envolvidos?
- Existem máquinas que apresentaram comportamento semelhante?

Usuários

- Quais usuários estão envolvidos?
- Algum usuário privilegiado está envolvido?
- As credenciais foram alteradas?
- O usuário reconhece a atividade?

Rede

- Quais IPs foram identificados?
- Existem conexões externas?
- Existem IPs ou domínios suspeitos?
- Houve comunicação entre máquinas internas?

Identidade

- Houve logins fora do padrão?
- Houve autenticações de localidades incomuns?
- Houve uso de VPN?
- Houve MFA?
- Houve criação ou alteração de contas?
- Houve alteração de privilégios?

Registrar tudo formalmente durante a reunião com o cliente.

Impacto no Negócio

Não assumir que um incidente técnico significa necessariamente um impacto ao negócio.

Perguntar e verificar se:

- Algum serviço está indisponível?
- Algum sistema crítico foi afetado?
- Houve perda de dados?
- Houve alteração ou exclusão de dados?

- Existe suspeita de exfiltração?
- Clientes ou usuários finais foram impactados?
- Existe impacto financeiro?
- Existe impacto regulatório ou contratual?
- Existe risco de interrupção operacional?

Pergunta-chave:

“Neste momento, qual é o impacto conhecido para o negócio?”

Qualquer alteração significativa na avaliação de impacto deverá ser registrada no ITSM.

Linha do Tempo

Construir uma timeline durante a War Room e registrá-la no chamado, quando possível.

Horário	Evento	Fonte	Evidência	Responsável
08:15	Primeiro alerta	EDR	Alerta X	SOC N1
08:23	Usuário identificado	Entra ID	Log	SOC N1
08:40	Host isolado	EDR	Ação registrada	SOC N1
09:10	Investigação iniciada	SOC	Ticket	SOC N2

Investigar e perguntar:

- Quando ocorreu o primeiro evento conhecido?
- Quando foi detectado?
- Quando o cliente tomou conhecimento?
- Quando foi realizada a primeira ação?
- Houve atividade anterior à detecção?
- Existe algum período sem logs?

Determinação da Atividade

Após entender o cenário, iniciar a investigação.

Investigação técnica e perguntas pertinentes

- Qual processo foi executado?
- Qual usuário executou?
- Qual máquina executou?
- Qual foi o processo pai?
- Qual comando foi utilizado?
- Houve criação de arquivos?

- Houve alteração de registro?
- Houve persistência?
- Houve execução remota?
- Houve movimentação lateral?
- Houve comunicação externa?
- Houve tentativa de elevação de privilégio?
- Houve acesso a credenciais?
- Houve transferência de dados?

Os resultados das análises realizadas deverão ser documentados no ITSM.

Determinação da Atividade

Antes de ações potencialmente destrutivas no ambiente do cliente, avaliar a necessidade de preservar as evidências.

Perguntar:

“Precisamos preservar evidências antes de realizar alguma ação de contenção?”

Avaliar:

- Logs.
- Eventos do Windows.
- Alertas do EDR/XDR.
- Processos.
- Memória, quando aplicável.
- Arquivos suspeitos.
- Hashes.
- Conexões de rede.
- DNS.
- Proxy.
- Firewall.
- Logs de autenticação.
- Cloud logs.
- Microsoft Defender.
- Microsoft Sentinel/Elastic.
- Entra ID.
- E-mails relacionados.

Registrar no ITSM:

- Qual evidência foi preservada.
- Onde está armazenada.
- Quem realizou a coleta.
- Data/hora da coleta.

- Referência ou identificação da evidência.

Importante: Não solicitar coleta indiscriminada. A preservação deve estar alinhada ao objetivo da investigação e aos procedimentos do ambiente.

Contenção

Depois de entender minimamente o cenário, discutir as opções de contenção.

Endpoint

- Devemos isolar o equipamento?
- Existe algum impacto operacional ao isolá-lo?
- Existe necessidade de manter o equipamento disponível para investigação?

Conta do usuário(a)s

- Devemos bloquear a conta?
- Devemos revogar sessões?
- Devemos redefinir credenciais?
- Existe risco de afetar sistemas críticos?

Rede

- Devemos bloquear IP?
- Devemos bloquear domínio?
- Devemos bloquear URL?
- Devemos bloquear comunicação entre segmentos?

Malware

- O arquivo deve ser colocado em quarentena?
- Existe risco de propagação?
- Existem outros hosts com o mesmo indicador?

Toda ação de contenção deve ser bem analisada e até alinhada com time de N2/Cliente, também deve ser formalmente registrada no ticket.

Exemplo possível:

Data/hora + ação + responsável + justificativa + resultado.

Propagação

Sempre considerar:

“Esse incidente está limitado a um ativo ou pode existir uma campanha maior?”

Investigar:

- Existem outros hosts com o mesmo hash?
- Existem outros hosts executando o mesmo processo?
- Existem outros usuários afetados?
- Existem autenticações semelhantes?
- Existem conexões para os mesmos IPs?
- Existem os mesmos domínios?
- Existem indicadores semelhantes?
- Houve movimentação lateral?
- Existem alertas correlacionados?

Novos ativos identificados devem ser adicionados ao escopo do incidente no ITSM.

Exfiltração

Caso existam indícios de acesso ou comprometimento de mais ativos:

- Houve transferência de arquivos?
- Para onde os dados foram enviados?
- Qual volume de dados foi transferido?
- Qual protocolo foi utilizado?
- Qual foi o destino?
- Houve compactação ou criptografia?
- Existem serviços externos envolvidos?
- Existem registros no firewall/proxy?
- Existe evidência de acesso a dados sensíveis?

Não afirmar exfiltração apenas porque houve comunicação externa.

Registrar claramente no ITSM se a situação representa:

- **Sem evidência de exfiltração**
- **Indício de possível exfiltração**
- **Exfiltração confirmada**
- **Investigação ainda inconclusiva**

Definição de responsáveis

Ao longo da reunião, definir de forma clara os responsáveis, exemplo:

Atividade	Responsável	Prazo	Status
Isolar endpoint	SOC N1/N2	Imediato	Pendente
Verificar logs Entra ID	IAM/SOC N1	30 min	Em andamento
Buscar IOC no EDR	SOC N1/N2 ou CTI	15 min	Concluído
Validar impacto	N2 (CSIRT)	1 h	Pendente

Toda ação definida na War Room deve possuir:

Responsável + prazo + status.

Evitar:

“Alguém pode verificar isso?”

Preferir:

“Carlos, você consegue validar os logs do firewall e retornar com o resultado?”

As tarefas devem ser registradas no ITSM sempre que a ferramenta permitir, caso não tenha acesso o gestor e o time superior devem ser notificados.

Exemplo:

SOC N1 ➤ SOC N2 ➤ Gestão SOC ➤ CTI / CTH N3 ➤ DFIR / Engenharia de Detecção N4

Atualização do ITSM Após a War Room

Ao final de cada War Room, o responsável pelo chamado deverá atualizar:

Situação atual

- Status do incidente.
- Severidade.
- Escopo conhecido.
- Impacto.
- IOCs identificados.
- Evidências coletadas.
- Contenção realizada.
- Hipóteses atuais.
- Pontos ainda desconhecidos.

Ações

Registrar:

- Ações concluídas.
- Ações pendentes.
- Responsáveis.
- Prazos.
- Dependências.

Comunicação

Registrar:

- Data/hora da War Room.
- Participantes.
- Principais decisões.
- Informações fornecidas pelo cliente.
- Próxima reunião, se aplicável.

Encerramento da Primeira War Room

Antes de encerrar, demos responder:

O que sabemos?

- Qual foi o evento inicial?
- Quais ativos estão envolvidos?
- Quais usuários estão envolvidos?
- Quais IOCs foram identificados?
- Existe comprometimento confirmado?
- Qual é o impacto conhecido?

O que não sabemos?

- Origem?
- Vetor inicial?
- Extensão?
- Persistência?
- Exfiltração?
- Outros ativos comprometidos?

O que foi feito?

- Contenção?
- Bloqueios?
- Isolamento?

- Reset de credenciais?
- Coleta de evidências?

O que falta fazer?

Definir claramente as próximas ações.

Todas essas informações devem ser refletidas no chamado de ITSM.

Fechamento e Comunicação

Finalizar com um resumo objetivo:

“Foi identificado um comportamento suspeito envolvendo [ativo/usuário]. Até o momento, foram identificados [principais evidências]. O impacto conhecido é impacto. Foram realizadas as ações de ações. Neste momento, permanecem em investigação [pontos desconhecidos]. As próximas ações são ações, sob responsabilidade de [responsáveis]. O chamado [ID] será utilizado como registro oficial da investigação e será atualizado conforme novos resultados forem obtidos.”

Encerramento do Incidente no ITSM

O chamado somente deverá ser encerrado após:

- Investigação concluída ou formalmente transferida.
- Escopo determinado dentro do possível.
- Contenção realizada, quando necessária.
- Erradicação realizada, quando aplicável.
- Recuperação validada.
- Evidências relevantes documentadas.
- Linha do tempo registrada.
- Ações realizadas documentadas.
- Pendências transferidas para os responsáveis adequados.
- Comunicação final realizada com o cliente.
- Conclusão do incidente registrada.
- Necessidade de lições aprendidas avaliada.

Registro da Conclusão

O encerramento deve responder os seguintes pontos:

O que aconteceu?

Qual foi a causa ou vetor identificado?
Quais ativos foram afetados?
Qual foi o impacto?
Quais ações foram realizadas durante o evento?
Existe algum risco residual?
Existem recomendações futuras para melhorar a postura de segurança?

Checklist Rápido – 5W + 1H

Durante a War Room:

- **What?** — O que aconteceu?
- **When?** — Quando aconteceu?
- **Where?** — Onde aconteceu?
- **Who?** — Quem está envolvido?
- **Why?** — Por que pode ter acontecido?
- **How?** — Como aconteceu?

Depois

Registro

Existe chamado no ITSM?

Escopo

1 Ativo ou vários outros?

Impacto

Existem impacto para o negócio?

Evidências

Quais fatos comprovam o comportamento?

Contenção

O ataque ainda está acontecendo?

Propagação

Existem outros ativos afetados?

Persistência

O atacante pode retornar futuramente?

Exfiltração

Existe evidência de saída de dados?

Ações

Quem fará o quê e quando?

Documentação

Tudo que foi decidido e executado está devidamente registrado?

Regra de Ouro da War Room

O analista de resposta a incidentes deve evitar entrar na reunião tentando **provar uma teoria**.

A postura correta é:

“Vamos entender o que aconteceu, determinar o escopo, preservar as evidências, reduzir o impacto e, com base nos dados coletados, determinar a causa e a extensão do incidente.”

Isso evita o chamado **viés de confirmação**, no qual a equipe encontra evidências apenas para confirmar uma hipótese inicial.

Fluxo Completo do Processo

Detecção ➤ Verificação existência de chamado no ITSM ➤ Utilizar chamado existente ou criar um novo chamado ➤ Abertura da War Room ➤ Registro dos participantes e contexto ➤ Entendimento do evento ➤ Determinação do escopo ➤ Avaliação do impacto ➤ Investigação ➤ Registro contínuo das atividades no ITSM ➤ Contenção ➤ Erradicação ➤ Validação ➤ Atualização final do chamado ➤ Comunicação de encerramento ➤ Encerramento do chamado ➤ Lições aprendidas.

Perguntas Essenciais – Versão de Bolso

Se você entrar em uma War Room sem saber exatamente o que perguntar, comece por essas perguntas:

1. **Existe um chamado de ITSM para este incidente?**
2. **Qual é o número do chamado que será utilizado como registro oficial?**
3. **O que aconteceu?**
4. **Quando identificamos o primeiro evento?**
5. **Qual foi a primeira evidência?**
6. **O incidente ainda está acontecendo?**
7. **Quais ativos estão envolvidos?**
8. **Quais usuários estão envolvidos?**
9. **Existe algum ativo crítico afetado?**
10. **Qual é o impacto para o negócio?**
11. **Temos evidência de comprometimento ou apenas uma detecção?**
12. **Existe evidência de movimentação lateral ou exfiltração?**
13. **O que já foi feito para contenção?**
14. **Quais evidências precisam ser preservadas?**
15. **Existem outros ativos com os mesmos indicadores?**
16. **Qual é a próxima ação?**
17. **Quem será responsável?**
18. **Qual é o prazo?**

19. A ação foi registrada no ITSM?

20. O que ainda não sabemos?

Princípios Fundamental de Documentação

Durante uma resposta a incidentes:

Se uma ação, decisão, evidência ou informação for relevante para compreender o incidente posteriormente, ela deve ser registrada no chamado.

O chamado deve permitir que outro analista consiga assumir a investigação e compreender:

O que aconteceu ➤ o que foi descoberto ➤ o que foi feito ➤ por quem ➤ quando ➤ por quê ➤ qual foi o resultado ➤ o que ainda precisa ser feito.

Responsabilidade do Analista de IR

O analista responsável pela resposta deve garantir que:

- O incidente possui um registro oficial.
- A documentação esteja atualizada.
- A timeline seja mantida.
- As evidências relevantes sejam referenciadas.
- As decisões sejam registradas.
- Os responsáveis sejam definidos.
- O cliente receba informações consistentes.
- O escopo seja continuamente reavaliado.
- O chamado permaneça atualizado até o encerramento.

A War Room é o ambiente de coordenação. O ITSM é o registro oficial da execução e da rastreabilidade do incidente.